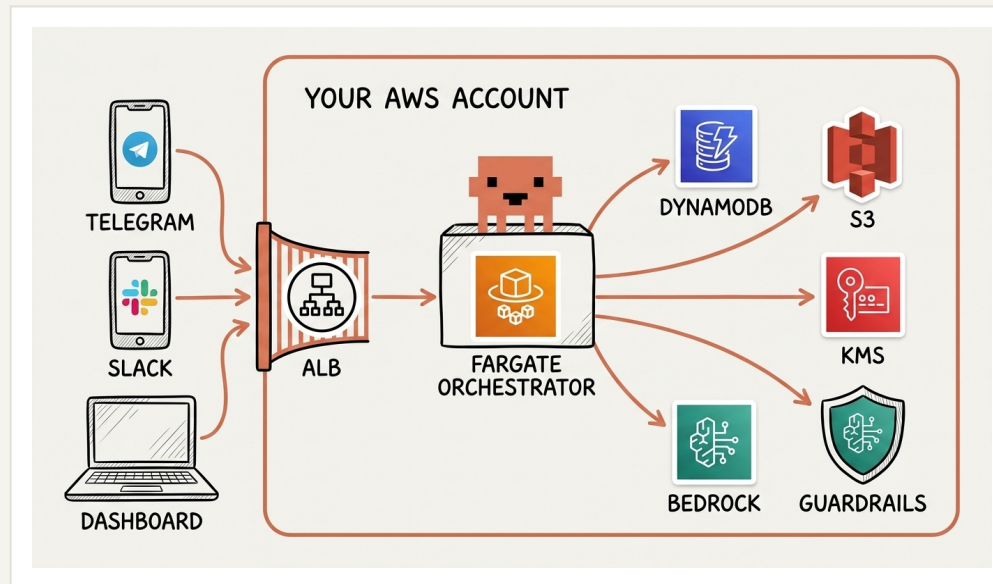


The Enterprise OS Blueprint

The complete plain-English reference for running a secure agentic AI operating system inside your own cloud. The architecture, every service, the compliance mental model, and the honest comparison, one read.



What's inside

CH 1	The Infrastructure, one account end to end (with a by-the-numbers map, the 15 stacks, and the leak scan)
CH 2	Every AWS Service in Plain English, with the cost and the gotcha for each
CH 3	What Compliance Actually Looks Like, the SOC 2 / HIPAA mental model and the evidence an audit wants
CH 4	Off-the-Shelf vs In-Your-Account, the honest comparison
PACK	The Build-It Prompt Pack (separate PDF) + the fill-in spec templates

CHAPTER 1

The Infrastructure

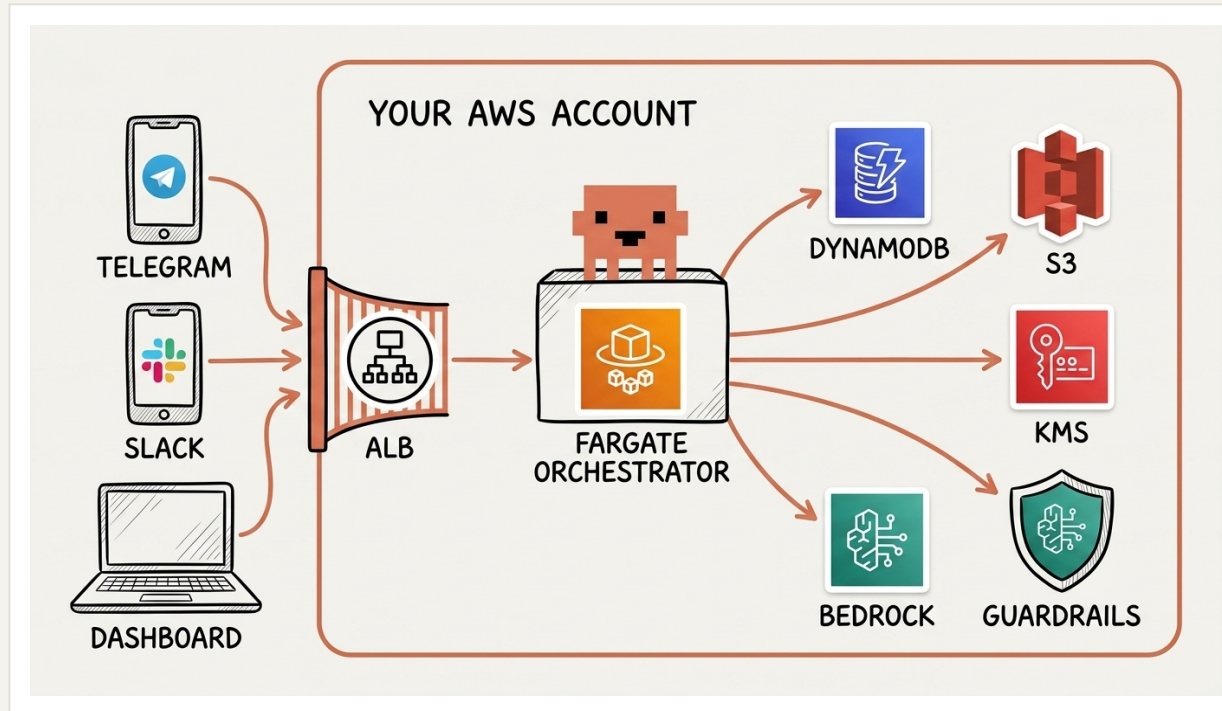
Exactly what stands up inside your own AWS account, drawn out and explained one piece at a time.

The whole system at a glance

1 AWS account	1 chokepoint	~31 DynamoDB tables	6 S3 buckets	3 KMS keys	42 kill switches
9 leak-scan patterns	15 CDK stacks	4 rollback classes	5 team roles	4 deploy tiers	7yr audit hold

Every number on this page is explained in the pages that follow. Hold the shape: one account, one chokepoint, your own keys, and a control for everything.

It all lives in one AWS account



THE ENGINE

One orchestrator in the middle runs every agent. Think of it as the single brain stem everything passes through.

THE DATA

Your tables, files, and settings sit in DynamoDB and S3, encrypted with your own KMS keys. Three customer-managed keys, never AWS-owned.

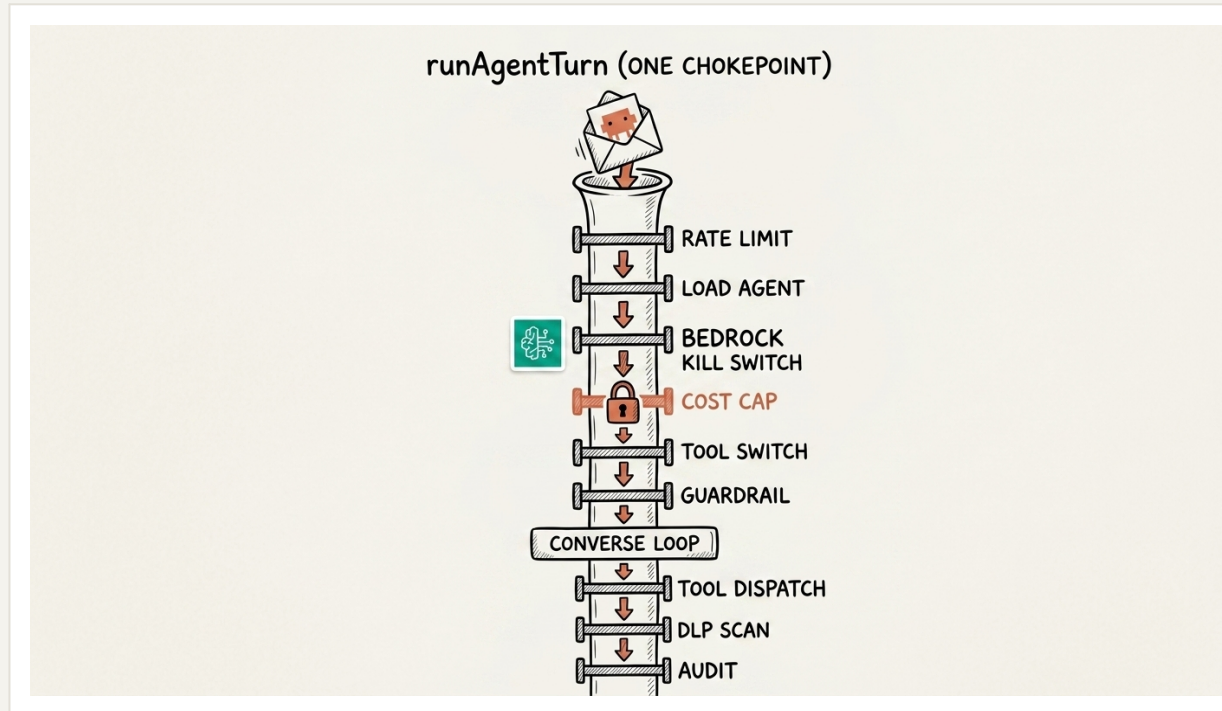
THE DOOR

Only the chat apps you choose reach in, through one guarded gate (the load balancer). Nothing else has a way in.

THE POINT

Nothing leaves the account. Delete it tomorrow and all of this is gone, because it was only ever here.

Every action funnels through one function



THE GATES IN ORDER

Rate limit, load-agent, the Bedrock kill switch, the cost cap, tool switch, guardrail, the converse loop, tool dispatch, DLP scan, audit. Every turn, top to bottom.

WHY IT MATTERS

Because everything goes through one pipe, every safety check happens in one place, not scattered across the system.

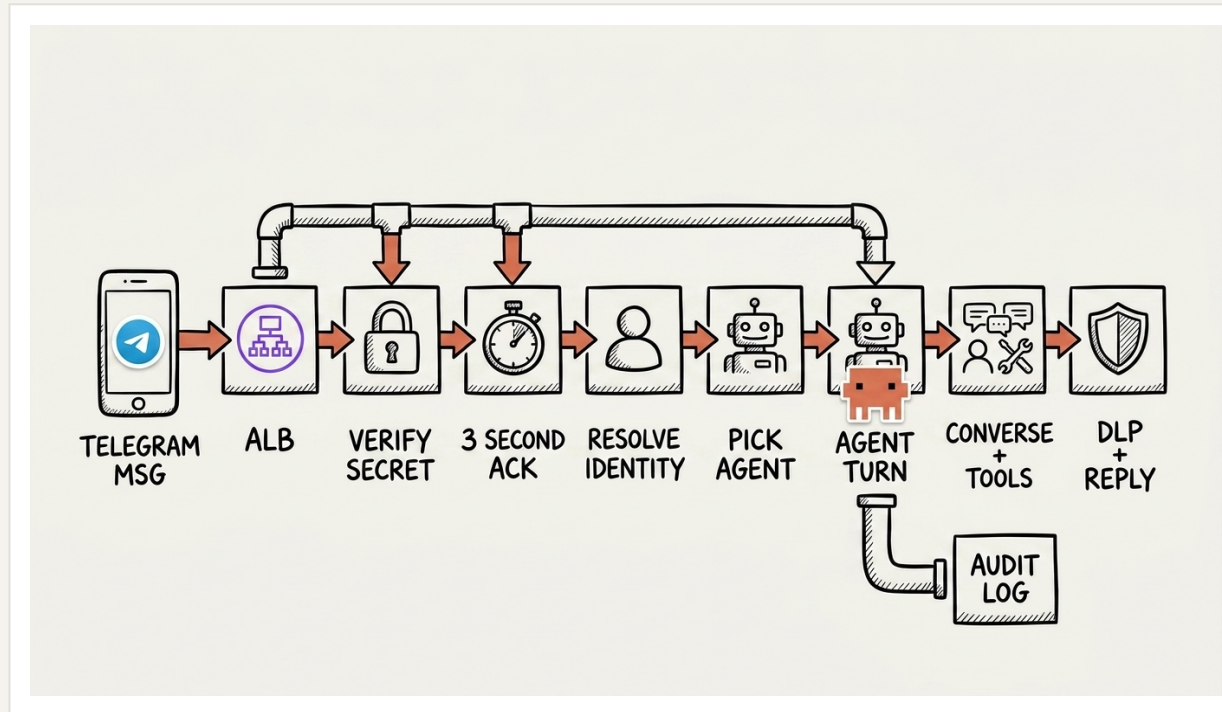
FAILS CLOSED

If the cost cap can't figure out what you've spent today, it stops, rather than letting the spending run.

THE BENEFIT

You're never hoping ten different parts all remember the rules. They check in one place, every time.

Follow one real message through the system



IT ARRIVES

A message comes in from a surface, hits the load balancer (the front door), and is verified as really from who it says.

3-SECOND ACK

It answers back within three seconds, so the surface never looks frozen while the agent thinks.

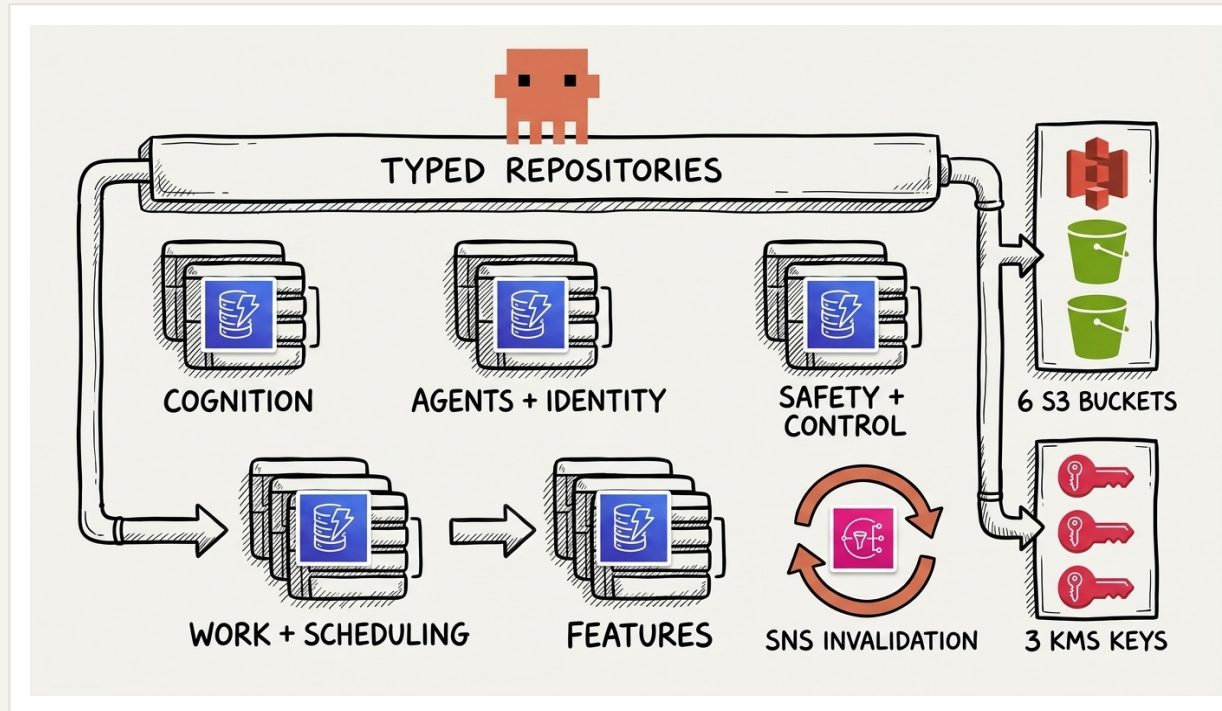
IT RUNS

Identity is resolved across your apps, the right agent is picked, the turn runs, and the reply is scanned for leaks.

IT'S LOGGED

The whole thing is mirrored into a write-once audit log. Every step is tied to a person and reversible.

Your data, on your own keys



THE TABLES

Around thirty-one DynamoDB tables grouped into cognition, agents and identity, safety and control, work and scheduling, and features. On-demand, no servers.

THE BUCKETS

Six S3 buckets hold documents, media, config, and the write-once audit log. Durable, private, yours.

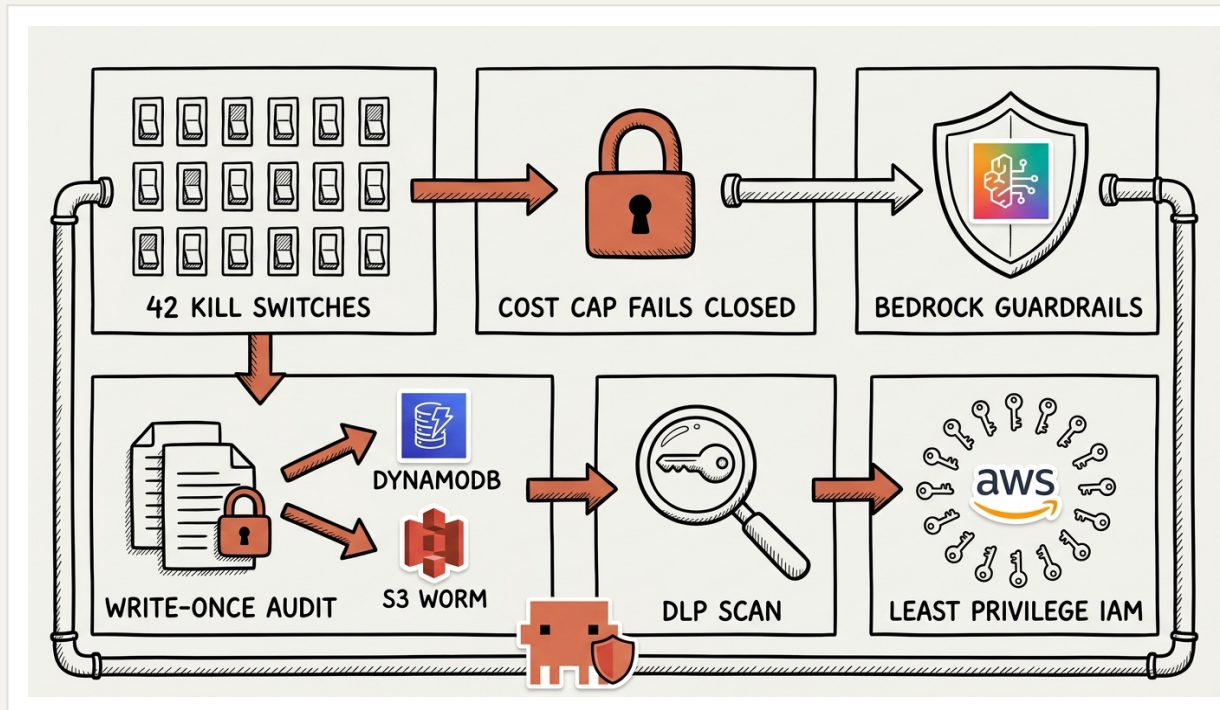
THE KEYS

Three customer-managed KMS keys encrypt everything. Pull a key and the data is unreadable, even to AWS.

SOVEREIGN

There's no copy on someone else's server. This is the line a security person actually cares about.

Six controls a security lead signs off on



KILL SWITCHES

Forty-two of them. Flip one and that behavior stops instantly, from a single agent to the whole system.

WRITE-ONCE AUDIT

Every action is dual-written: a hot copy in DynamoDB plus a write-once S3 Object Lock trail (governance mode, seven-year hold, tier 2 and up). You can't quietly switch it off.

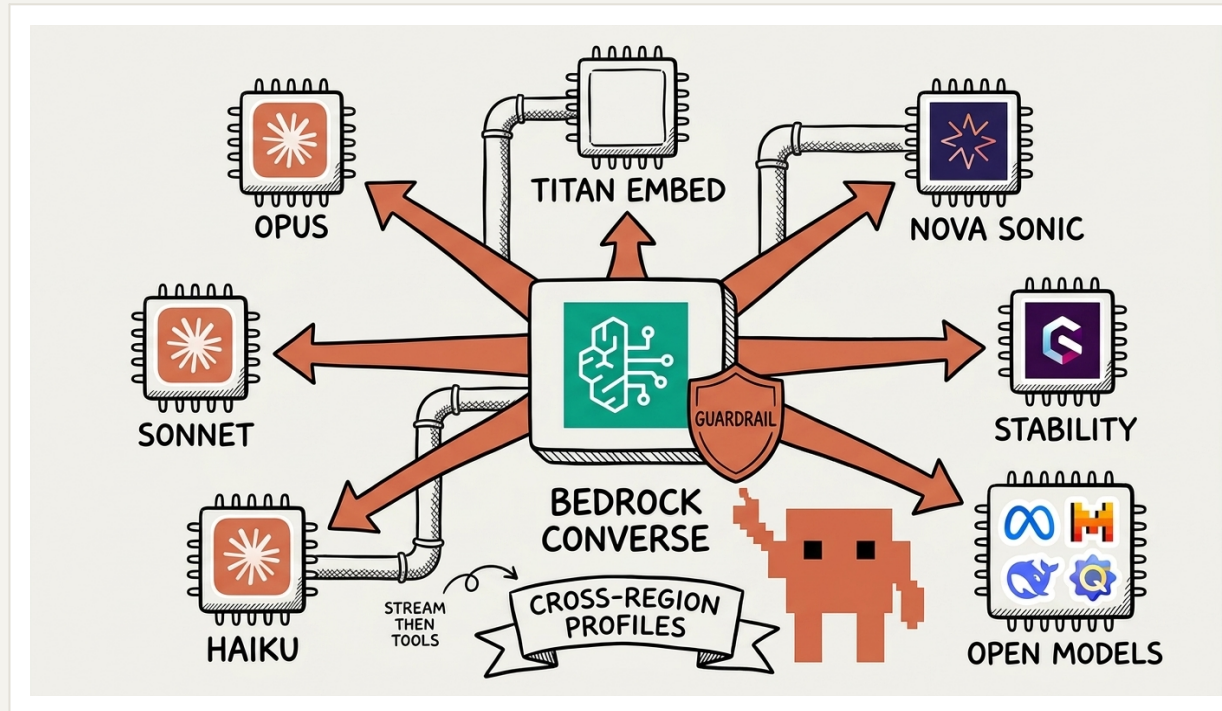
GUARDRAILS + DLP

Nine leak-scan patterns run on every reply, catching keys, tokens, cards, and SSNs before anything leaves.

LEAST PRIVILEGE

Every part can do only its one job. No master keys, nothing over-permissioned.

Any model, still in your account



CLAUDE

Opus, Sonnet, and Haiku for the thinking. Routed through Bedrock so the prompt never leaves your account.

AMAZON'S OWN

Nova Sonic for voice, Titan for search and embeddings, Stability for images, all in-account.

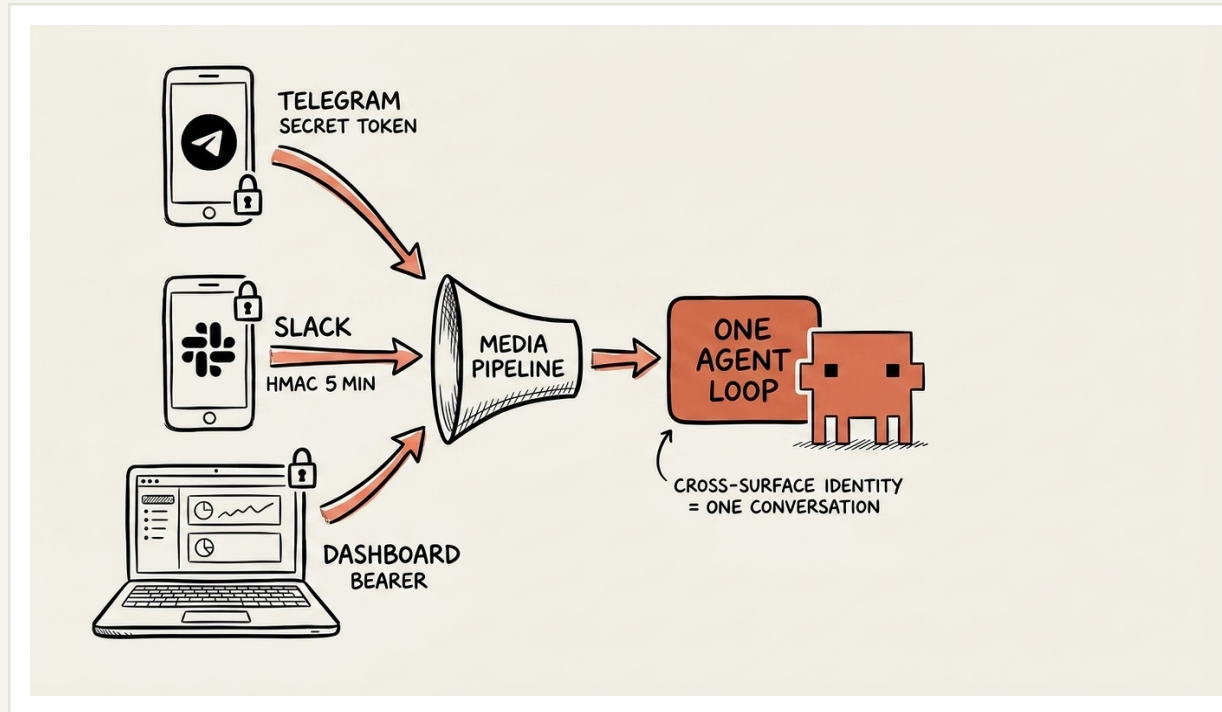
OPEN MODELS

Llama, Mistral, DeepSeek, Qwen. Run one when policy says no outside vendor.

CROSS-REGION

Bedrock cross-region inference profiles spread load, and the prompt still never leaves your walls.

Telegram, Slack, or the dashboard



THREE DOORS

Telegram with a secret token, Slack with a five-minute HMAC, the dashboard with a bearer or magic-link session. Each verified its own way.

ONE AGENT

All three funnel into one agent loop. The plumbing behind them is shared, not duplicated.

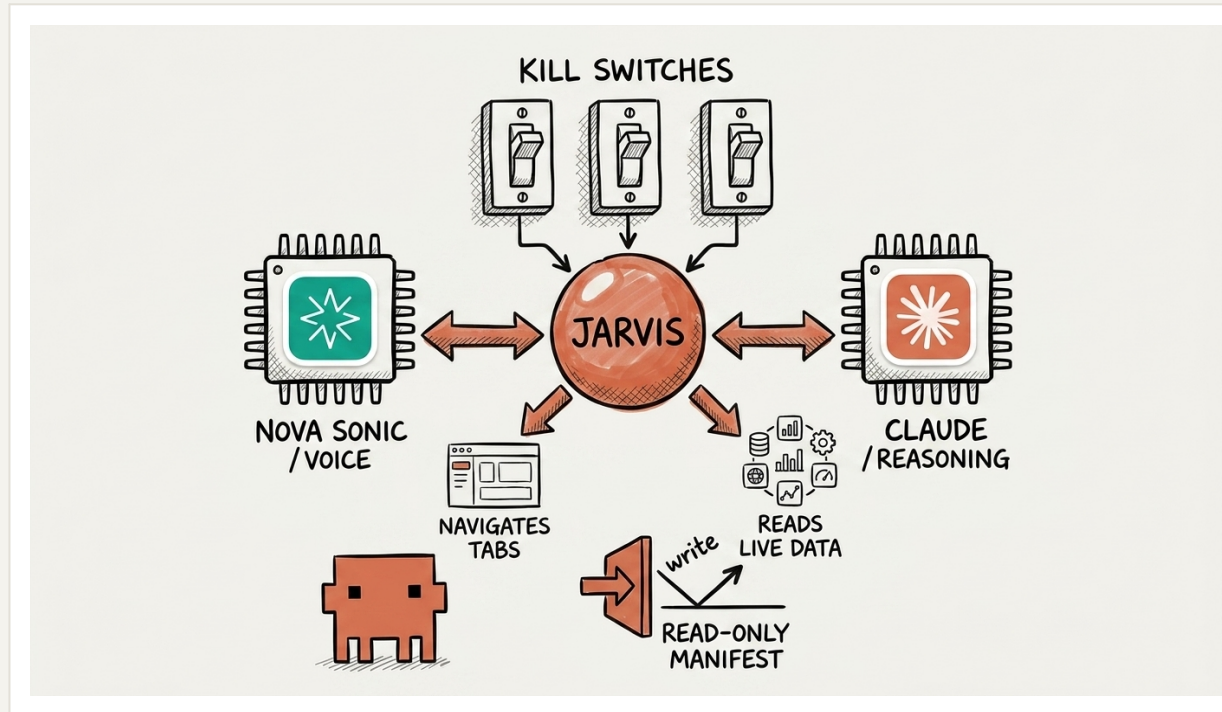
ONE PERSON

Start in Slack, pick it up in Telegram, it's the same conversation. The system knows you're one person.

MEDIA TOO

A shared media pipeline handles images and files coming in across every surface.

The voice copilot, read-only by design



TWO BRAINS

Nova Sonic is the voice (listening and speaking), Claude is the reasoning behind it.

READS LIVE

It reads the same live data the dashboard reads, so what it tells you is real, not made up.

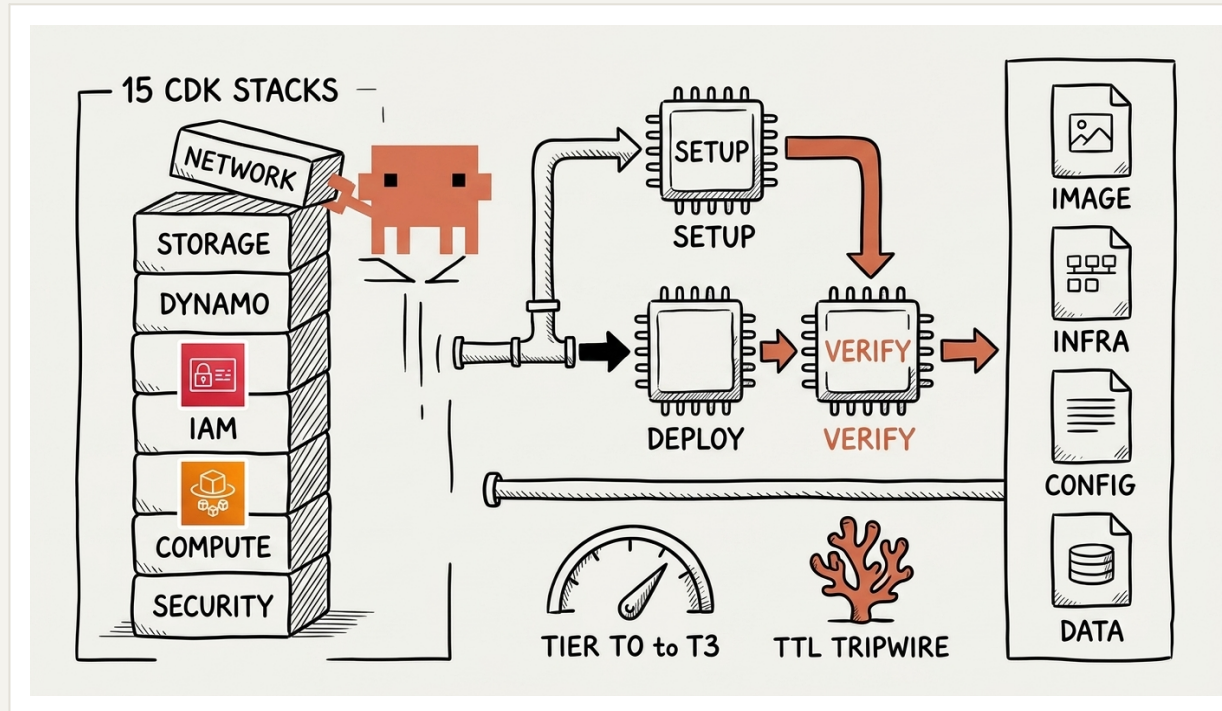
FAIL-CLOSED

It sits behind a read-only manifest and three kill switches. Writes bounce off the gate.

SO IT'S SAFE

The most sci-fi feature in the system is also the one that can't touch your data. That's the point.

Fifteen stacks, three commands



AS CODE

The whole system is fifteen CDK building blocks that lay down in dependency order. Nothing clicked by hand.

THREE COMMANDS

Set up, deploy, verify. The blueprint gets you most of the way before you touch anything.

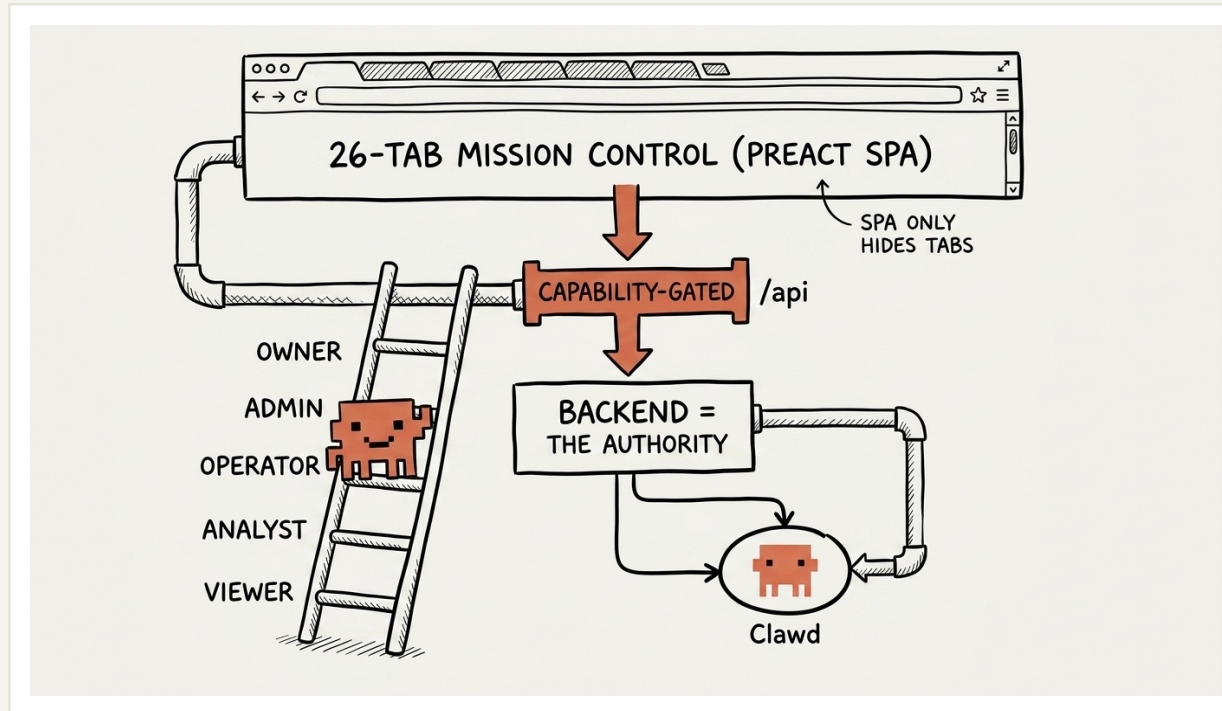
FOUR ROLLBACKS

Image, infrastructure, config, and data. Something breaks, you step back along the right axis.

THE TRIPWIRE

Start an install and walk away, and a TTL tripwire tears it down so you're not paying for a half-built thing.

Roles, with the backend as the authority



THE LADDER

Five roles, bottom to top: viewer, analyst, operator, admin, owner. Each sees only what its role allows.

BACKEND RULES

The dashboard only hides tabs. The backend is the real authority on who can do what.

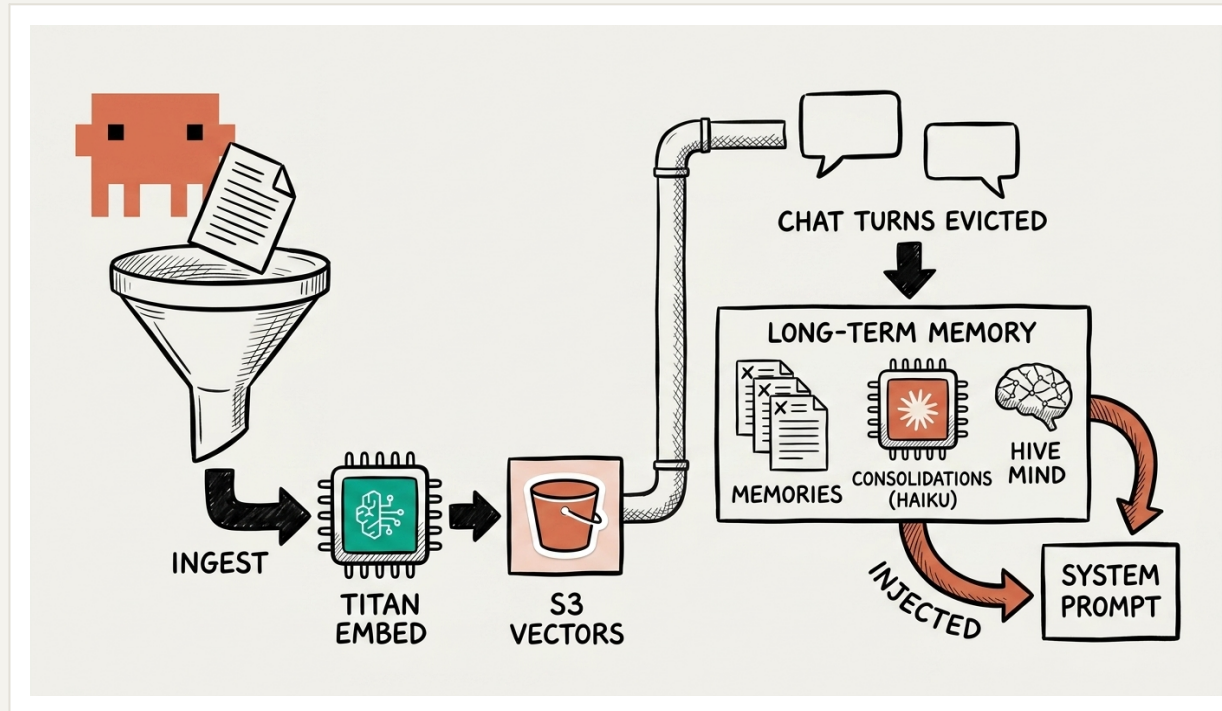
REAL CHECK

Every action runs through a capability-gated API. Get clever in the browser and the backend still says no.

GOVERNED

Every privilege-changing action is attributed to a real person, on the record.

Your documents, embedded in your account



INGEST

Point it at your files. They get turned into something searchable, the embed step, and stored in your account.

EMBED + STORE

Titan turns documents into vectors that live in your own S3. The agent looks them up before it answers.

MEMORY

Old conversations get distilled into long-term memory, so it remembers without re-reading everything.

SECURE

All of it, the documents, the vectors, the memory, stays inside your walls.

What lays down, in dependency order

Defined as code, deployed in order. You don't click any of this together by hand.

FOUNDATION

Network (the VPC and subnets), Storage (the buckets), Secrets, Dynamo (the tables), and IAM (the roles). The base everything else sits on.

RUNTIME

Compute (Fargate, the engine), Messaging (the surfaces and queues), and Extensions (pluggable capabilities).

SAFETY

Guardrails (the model-level filters), Security (kill switches, audit, DLP), and CostGuardrails (the budget and the daily cap).

OPS

Observability (CloudWatch, alarms), Backup, Chaos (failure testing), and CodeBuild (the deploy pipeline).

Nine patterns, on every single reply

BLOCK ON SIGHT (7)

AWS access keys, API key headers, private keys (PEM), Slack tokens, GitHub personal access tokens, credit cards, and US social security numbers. Caught before the reply ever leaves.

WARN (2)

AWS-secret-key-shaped strings and JWTs. Flagged rather than blocked, because they false-positive on legitimate tokens.

ON EVERY REPLY

The scan runs on every single agent reply, not a sample. It's the last gate before anything reaches a human or a surface.

THE HONEST LIMIT

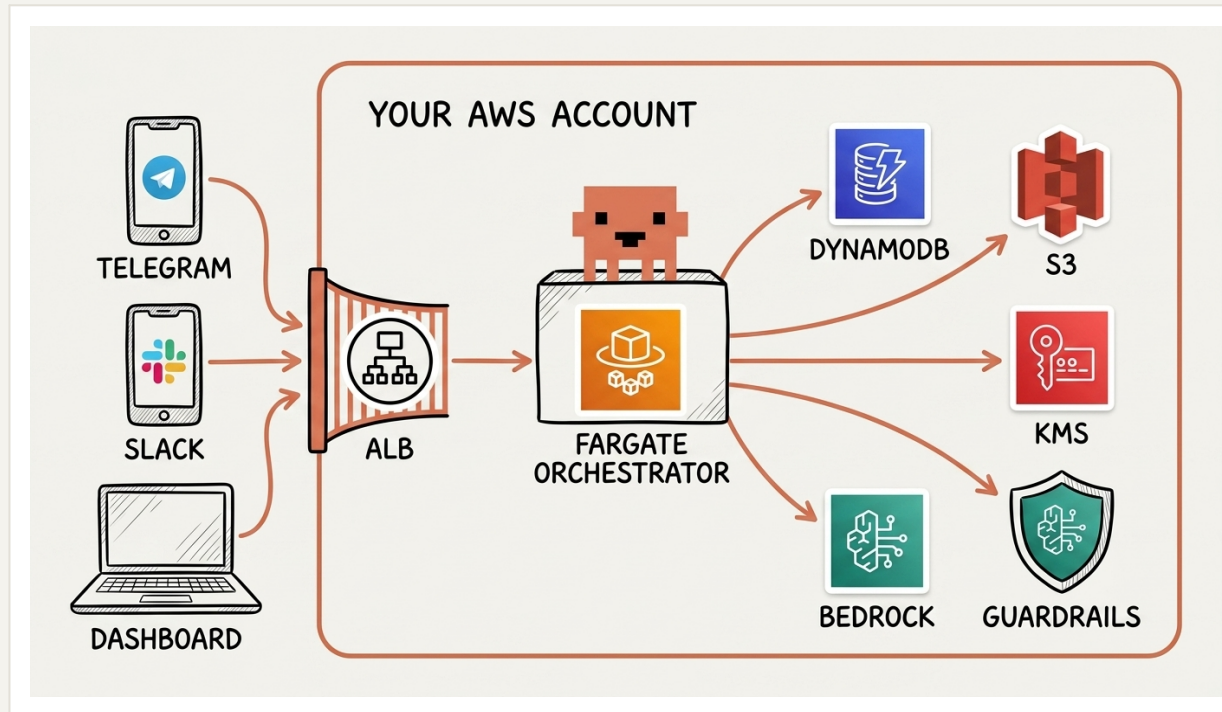
It's a backstop for the obvious stuff, not a magic catch-all. Pair it with the habit of not pasting secrets into prompts in the first place.

CHAPTER 2

Every AWS Service, in Plain English

What each piece of the stack is, what it does here, and the one cost or gotcha worth knowing. No jargon left standing.

What runs it, and what guards the entrance



FARGATE · the engine

Runs your agents as containers, no server to babysit, the orchestrator everything passes through. Watch: it runs on ARM64 (about 20 percent cheaper than x86) and it's always on, so it's part of your fixed monthly floor.

LOAD BALANCER · the front door

One guarded entrance that routes incoming requests in. Nothing reaches the agents except through here. Watch: roughly 22 dollars a month even idle, a fixed cost from day one.

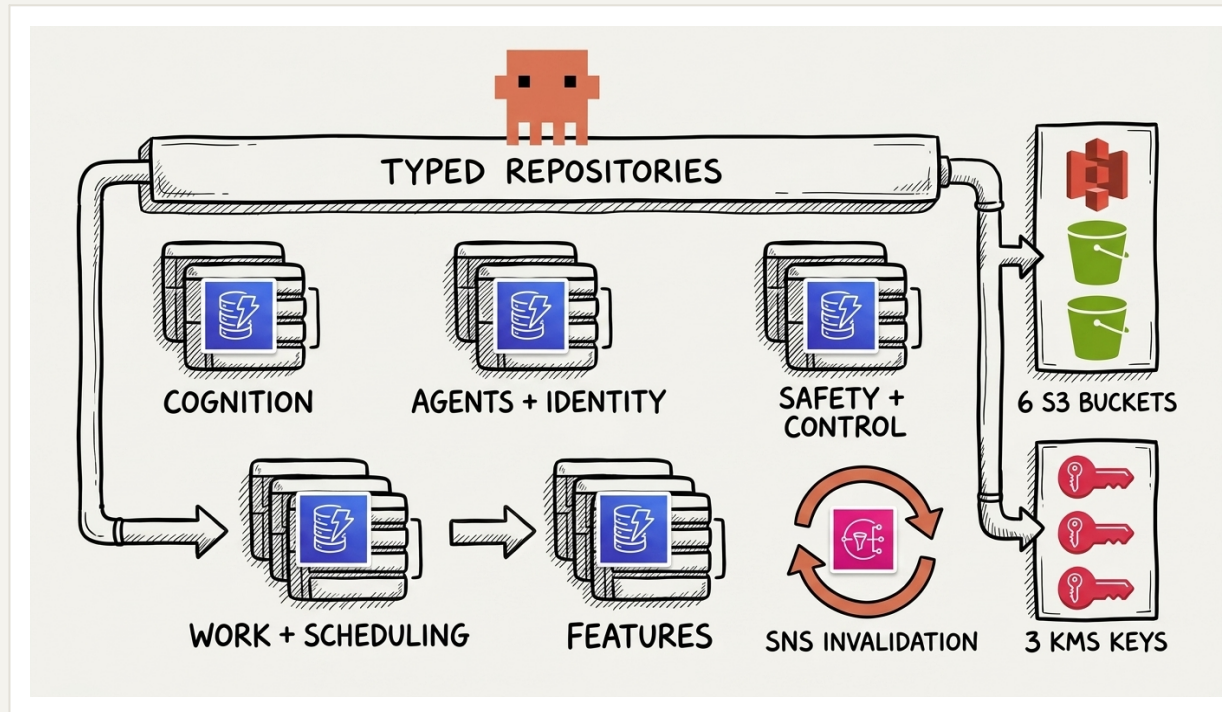
LAMBDA · the workers

Small functions that fire for scheduled tasks and background jobs. Watch: you pay per invocation and duration, usually pennies at this scale, nothing while idle.

VPC + WAF · network and firewall

The VPC walls the system off, the WAF filters bad traffic before it lands. Watch: NAT gateways inside the VPC run about 33 dollars a month each and are one of your biggest fixed lines.

Where everything lives, and who can unlock it



DYNAMODB · the database

Fast tables holding memory, settings, and records, inside your account.
Watch: on-demand billing means you pay per request, cheap at low volume, no idle cost.

S3 · the file storage

Buckets for documents, media, and the write-once audit log. Watch: the audit bucket uses Object Lock, so it intentionally can't be emptied on a whim.

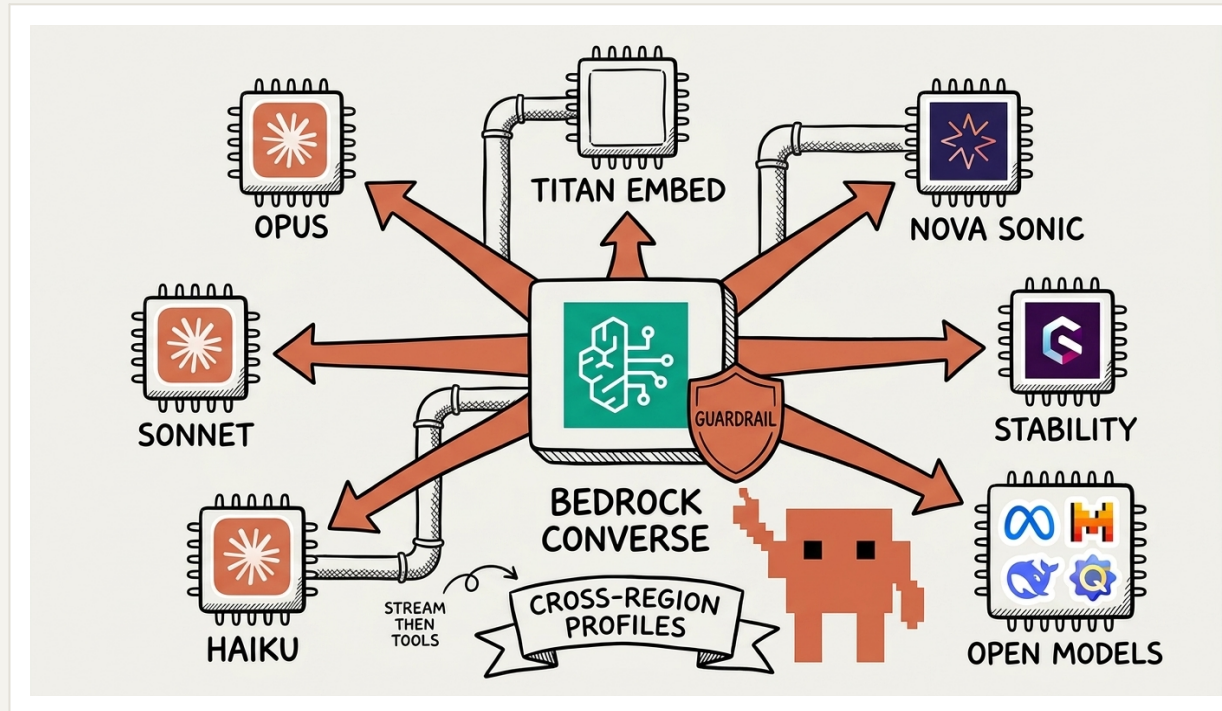
KMS · the keys

Your encryption keys. Everything is scrambled with keys only you hold.
Watch: about a dollar per key per month plus per-request, three keys here, trivial cost but central to everything.

SECRETS MANAGER · the vault

Credentials live here, encrypted and rotated, never in a plain text file.
Watch: roughly 40 cents per secret per month, rotate them, don't hardcode.

The models, and how they stay in-account



BEDROCK · the AI runtime

AWS's way of running models inside your account. Every call goes through here, prompts never leave. Watch: you must request model access per region in the console first, and it can take a few minutes to propagate.

NOVA · Amazon's models

Nova Sonic is the voice for Jarvis, the part that listens and speaks. Watch: voice is metered per use, part of variable inference, not a fixed cost.

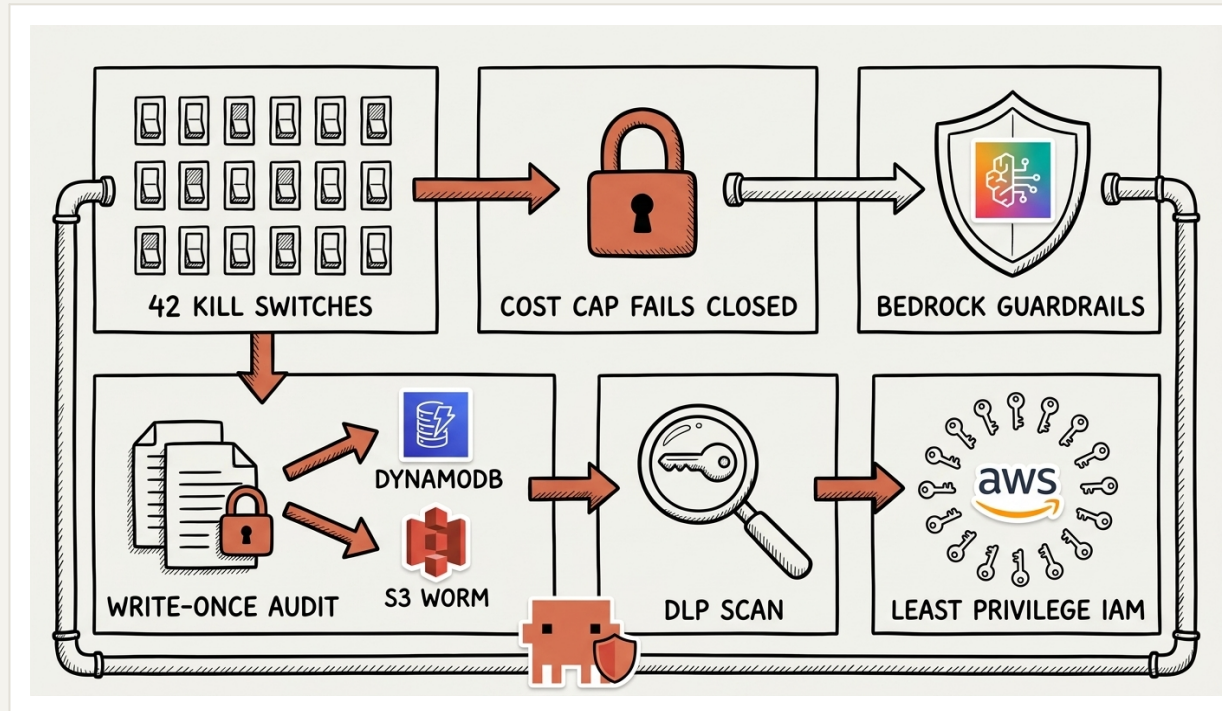
TITAN · the search brain

Turns your documents into something the agent can look up before it answers. That lookup is RAG. Watch: embeddings are fractions of a cent per thousand tokens, but they add up at scale.

OPEN MODELS · the escape hatch

Llama, Mistral, DeepSeek, Qwen, run in-account when policy says no outside vendor. Watch: great for strict no-vendor rules, the prompt still never leaves.

The controls that let a security team say yes



IAM · who can do what

Every part gets only the permission for its one job. No master keys. Watch: free to use, and the single most important thing to get right, least-privilege is the whole game.

GUARDDUTY · the threat detector

Watches the account for suspicious activity and flags it. Watch: priced on event volume, a few dollars a month at low activity, scales with traffic.

CLOUDWATCH · the eyes

Metrics, logs, and alarms, the way you see what's happening. Watch: logs have an ingestion and retention cost, set sane retention so it doesn't creep.

SNS · the alert pipe

Sends alarms and notifications out to you so a problem reaches a human fast. Watch: effectively free at alert volumes.

CHAPTER 3

What Compliance Actually Looks Like

A plain-English mental model for SOC 2 and HIPAA, and how a system like this maps to it. A way to think, not a certificate.

A mental model, not legal advice

Before any of the rest, the honest framing.

NOT LEGAL ADVICE

This is a mental model to help you reason about compliance, not legal, security, or audit advice. For your actual obligations, talk to a qualified auditor or counsel.

IT DEPENDS

Real compliance depends on your jurisdiction, your industry, the data you hold, your scope, and the auditor you choose. The same system can pass for one org and not another.

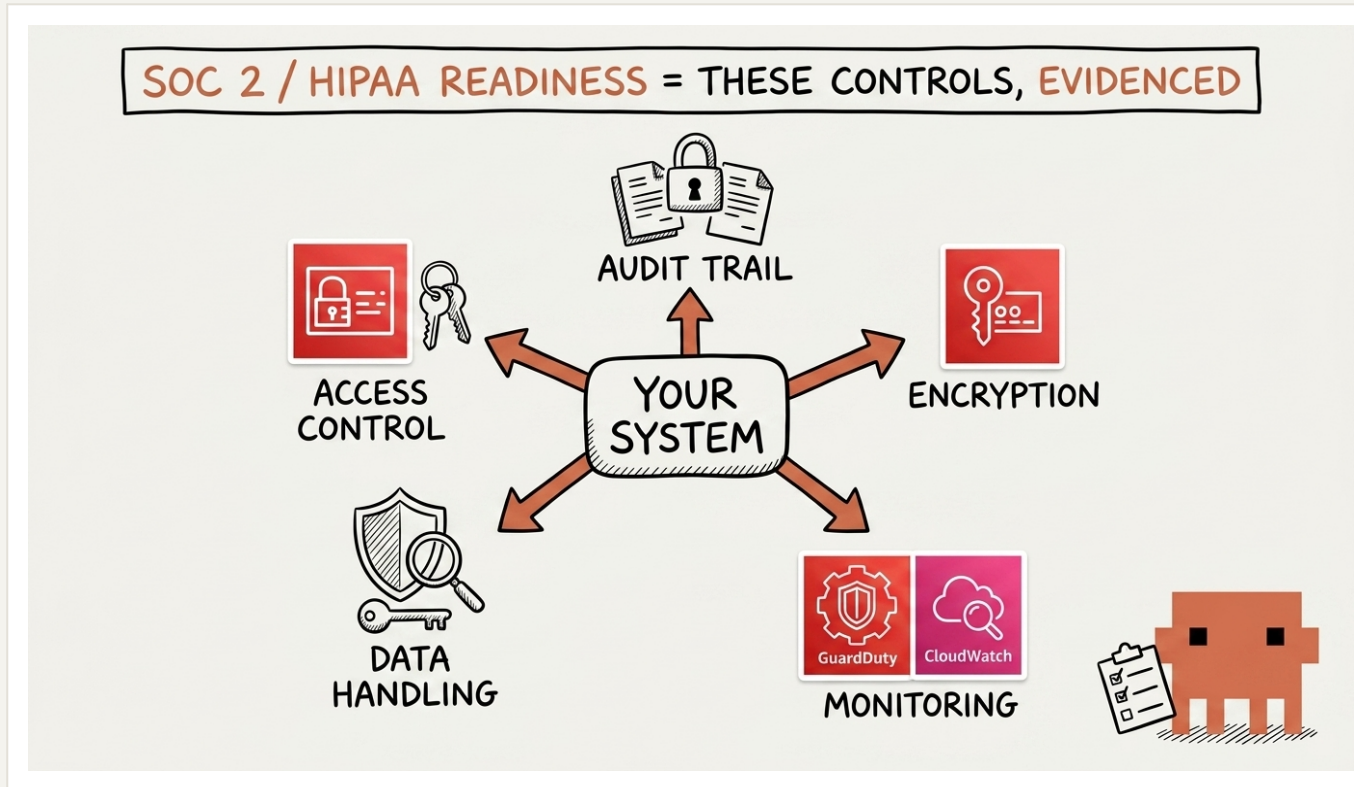
READINESS, NOT A CERTIFICATE

Software can get you ready and keep you evidenced. It cannot certify you. A certificate comes from an independent audit, never from a dashboard.

WHY A MODEL HELPS

Most teams freeze because compliance feels like a black box. Break it into a few control categories and it becomes a checklist you can actually work.

Compliance, broken into five categories



What each control category actually means

ACCESS CONTROL

Who can touch what. Least-privilege roles (IAM), team roles (RBAC), and the rule that the backend, not the screen, decides.

AUDIT TRAIL

A record of who did what, and when. A write-once log you can't quietly edit means you can actually prove it later.

ENCRYPTION

Data scrambled at rest and in transit, with keys you control (KMS). If it leaks, it's unreadable.

MONITORING

Eyes on the system. Threat detection (GuardDuty) plus metrics and alarms (CloudWatch), so problems surface fast.

DATA HANDLING

Where data lives and how it's allowed to leave. In-account storage, leak scanning before anything goes out, and a defined retention story.

Frameworks come down to evidence

Auditors don't take your word. They want artifacts. Here's the kind, mapped to the five categories.

FOR ACCESS

Your IAM policies, the role definitions, a list of who holds which role, and proof the backend enforces it, not just the UI.

FOR AUDIT

Samples from the write-once log showing actions tied to people and timestamps, plus proof the trail can't be silently disabled.

FOR ENCRYPTION

Your KMS key policies, evidence data is encrypted at rest, and that TLS is enforced in transit.

FOR MONITORING + DATA

GuardDuty and CloudWatch configs, the DLP pattern list, your retention policy, and an incident runbook.

SOC 2 and HIPAA, in one line each

SOC 2 IN ONE LINE

Are you trustworthy with data? An auditor checks your controls (security, availability, confidentiality) against the criteria and writes a report. It's about your practices.

HIPAA IN ONE LINE

Are you safe with health data? US rules for anyone handling protected health information: safeguards, access limits, breach rules, and a signed agreement (a BAA) with partners.

WHAT THEY SHARE

Both come down to the same five categories: access, audit, encryption, monitoring, data handling. Get those evidenced and most frameworks rhyme.

THE EVIDENCE GAME

A system that emits evidence continuously, logs, configs, a readiness score, is doing the hard part of an audit for you, all year, not the week before.

Turn the model into a loop

START WITH POSTURE

Run a readiness check and see which controls are met, partial, or a gap. That snapshot is your map.

CLOSE THE GAPS

Fix a batch, re-scan, repeat, until only the human sign-off items are left. Software is great at this part.

KEEP THE EVIDENCE

Compliance isn't a one-time push. The real win is a system that stays evidenced as you operate it.

THEN BRING IN THE PRO

When you're ready, an auditor or counsel takes you the last mile for your specific situation.

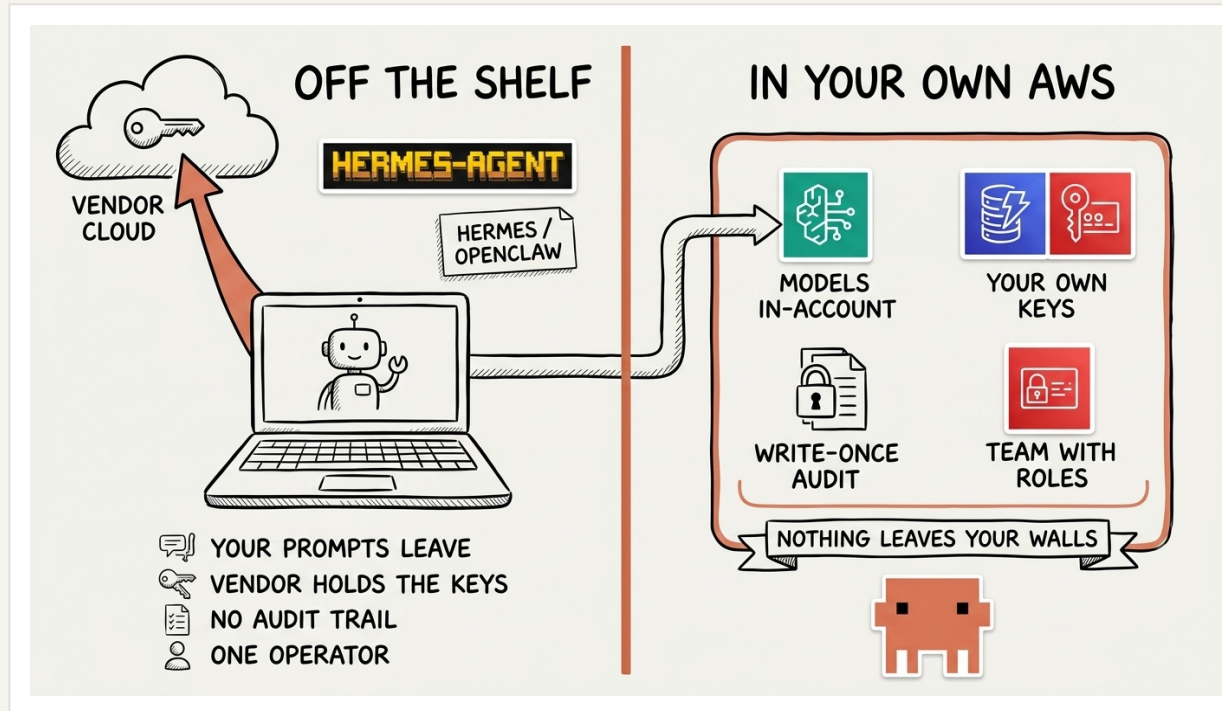
A dashboard can't make you compliant. It can make you ready, and keep you honest. The certificate still comes from a human audit.

CHAPTER 4

Off-the-Shelf vs In-Your-Account

The honest difference between a hosted agent like Hermes or OpenClaw and running the same capability inside your own cloud.

Same capability, different ground



SAME CAPABILITY

This isn't ours is smarter. Both can read your email and run tools. The whole difference is where it all happens.

OFF THE SHELF

Fast to start, zero infrastructure. Your prompts and data ride to a vendor's servers, and they hold the keys. Perfect when the data is yours to share.

IN YOUR ACCOUNT

More to stand up, but the model, the data, and the keys never leave your walls. Built for when the data isn't yours to hand over.

THE LINE

Solo or low-stakes? Off the shelf is great, go use it. Regulated, or someone asks where does our data go? That's when you bring it home.

The same questions, both ways

WHERE DATA GOES

Off the shelf: to the vendor's servers. In your account: nowhere, it stays inside your own AWS.

WHO HOLDS THE KEYS

Off the shelf: the vendor holds them. In your account: you do, with customer-managed KMS keys.

AUDIT

Off the shelf: whatever they choose to expose, if anything. In your account: a write-once audit trail you control.

MODELS

Off the shelf: the model they picked. In your account: any model via Bedrock, including open models that never leave.

TEAM AND ACCESS

Off the shelf: usually one operator. In your account: real roles, least-privilege, the backend as the authority.

COST SHAPE

Off the shelf: a simple subscription. In your account: a fixed infra floor plus inference you can tune. More control, more responsibility.

It's a trade, not a religion

STAY OFF THE SHELF IF

You're solo or small, the data is yours to share, and speed to start matters more than control.

COME IN-ACCOUNT IF

You handle data that isn't yours to hand over, you need an audit trail, or a security review is somewhere in your future.

YOU CAN DO BOTH

Use off-the-shelf for low-stakes speed and the in-account system for the sensitive work. Pick per job, not per identity.

THE HONEST TRADE

In-account isn't free or effortless. You trade convenience for control. For the right data, that trade is the whole point.

GET THE REPO + GO DEEPER

Want the actual build, not just the blueprint?

It all lives in the Early AI Dopters community, and that's where the repo stays:

THE EXACT REPO

The full Enterprise OS codebase to clone and deploy inside your own AWS account.

THE TRAINING

Build modules that walk through how it was made, from zero, so you can stand up your own.

PREMIUM COACHING

Hands-on help to optimize it and set it up for your own organization, with me and the team.

THE WORKING GROUP

Founders and operators building secure, in-account AI together, sharing what works.

Join here: <https://www.skool.com/earlyaidopters/about>